

## AR 517: Introduction to Cyber security

|               |                                         |
|---------------|-----------------------------------------|
| Course Code   | AR 517                                  |
| Course Name   | Introduction to Cyber security          |
| L-T-P-C       | 3-0-0-3                                 |
| Prerequisites | Knowledge of basic computer terminology |
| Intended for  | Undergraduate (Elective)/ Postgraduate  |
| Approval      | 54th BoA (May 2024)                     |

### Course Modules

- Domain 1: Understand the basic fundamentals of cybersecurity including asset, data protection and risk assessment and management
- Domain 2: Learning cryptography, network security and the core concepts of holistic security models and architecture
- Domain 3: Explore the Identity and access management ecosystems
- Domain 4: Respond and mitigate cybersecurity attacks and understanding of the entire landscape

### Course Contents

#### Domain 1: Understanding Security, Total hours – 14 Hours

- Unit 1: **Understanding Security Governance Principles Types of plans:**
  - Strategic, Tactical and Operational Understanding and Applying Security Concepts, Confidentiality (Data at Rest, Motion and in Process), Integrity (Preventing unauthorized modification) and Availability (Always available data) , Access Control Methodologies: IAAA
  - Understanding Risk Management: Defining Assets Threats, Vulnerabilities risk, Exposure, Breach, Countermeasures, Safeguards, Covering Risk Analysis/Assessment, Qualitative and Quantitative Process, Cost Benefit Analysis, Dealing with Risk (Concept of MATAR), Understanding Risk Frameworks, NIST 800-37 and NIST 800-53A, Control Types: Administrative, Technical and Physical, Control Methodologies or Mechanism, Threat Modelling , Intellectual Property: Trade Secrets, Patent, Copyright and Trademarks
  - Defining the various DRP and BCP Plan and how they help organisation, Detailing the incident response process, and designing an Incident Response Plan workflow. Understanding ISO 27001 and ISO 22301
- Unit 2: **Data and Asset Management**
  - Policies, Standards, Procedures, and Guidelines, Data classification vs categorisation, Security Roles and Responsibilities, Managing the data and asset lifecycle , Destruction, Purging, Clearing Understanding Personal data, Information lifecycle: Creation, Store, use, Achieve and Destroy, GDPR and DORA (Digital Operational Resiliency Act)
- **Suggested Reading**
  - Kim. D., and Solution, M.G., **Fundamentals of Information System Security**, Jones & Bartlett Learning, 2010
  - Paul A. Watters, **Cyber Security: Concepts and Cases**, Create Space Independent Publishing Platform, 2012.
  - Peter W. Singer, Allan Friedman, **Cybersecurity: What Everyone Needs to Know**, Oxford University Press.
  - David Sutton, **Cyber Security: A Practitioner's Guide**, BCS Learning & Development Limited, 2017

#### Domain 2 : Network Security and Cryptography, Total Hours – 14 Hours

- Unit 1 :
  - Understanding Security Models and Architecture Lattice based vs Rule based, Enterprise Security Architecture, Security Frameworks i.e., Risk vs Privacy vs Security
  - Understanding security systems: Client and Server system, Industrial Control Systems (ICS), Cloud-based systems (e.g., Software as a Service (SaaS), Infrastructure as a Service (IaaS), Platform as a Service (PaaS))
  - Cryptography: Understanding Plaintext, ciphertext, key, encrypt, decrypt, IV, Confusion, diffusion, work factor, Key Lifecycle and Management, methods (Symmetric and Asymmetric), Substitution vs Transposition, Hidden watermark, PKI, Hashing, Digital signature, Fundamental of Non-repudiation,
  - Cryptanalytic attacks: MITM, Side Channel attack, Brute Force, Ciphertext only, Known plaintext, fault injection, rainbow attack, Birthday attack
  - Physical Security: Control Category, Deter, Delay, Detect, Assess and Respond, Layered defence inclusive of perimeter , infra , fire detection and suppression and Building Management System (BMS)
- Unit 2 : Network Security
  - OSI Model and TCP/IP Model Layer 1-Layer 7 : Physical, data , network, transport, session, presentation and Application layer
  - Understanding the Networks: WAN, Wireless, IP Protocols, Converged Protocols, Network Authentication Defense in Depth, Routers, switches, Bridge, proxy, Port addressing, Firewalls: Firewall Basics, Types of Firewalls, Network Address Translation Issues, Public and Private address, Ingress and Egress, Understanding Virtualisation Remote Access: Tunnelling,
  - Remote Authentication, Remote Access Management, IPsec Protocols, VLAN

### Suggested Reading

- Kahate, A. Cryptography and Network Security, McGraw-Hill Higher Ed., 2009.
- Riggs, C., Network Perimeter Security: Building Defence In-Depth, AUERBACH, USA, 2005.
- Northcutt S., Inside Network Perimeter Security, 2nd Edition, Pearson Education, 2005.
- Stallings, W., Network Security Essentials: applications and standards, 3rd Edition, Pearson Education India, 2007.
- Douglas E. Comer, Internetworking with TCP/IP, Principles, Protocols, and Architecture, Addison-Wesley, 5th Edition, Vol 1, 2005 .
- Douglas E. Comer, David L. Stevens, Internetworking with TCP/IP Vol. III, Client Server Programming and Applications, 2nd Edition, Addison-Wesley.
- Behrouz A. Forouzan, Data Communications and Networking, McGraw-Hill, 5th edition.
- Domain 3 : Access Control, Total Hours – 6 Hours
- Unit 1: Secure Design Principles
  - Defense of depth, principle of least privilege, Separation of duties, Need to know, Zero Trust Management Approach: Centralised, Decentralised and Hybrid Authorisation vs Authentication, Type of authentications, (Knowledge vs ownership vs characteristic)
  - Single Sign on (SSO) vs Federated Identity, Management of Authorisation mechanism: Rule based access, Role based access, DAC, ABAC, MAC, Identity and access provisioning lifecycle, Understanding Authentication system: OAuth, OpenID SAML, SPML, Remote Authentication, Kerberos, IDaaS Identities

### Suggested Reading

- Omondi Orondo, **Identity & Access Management: A Systems Engineering Approach**
- Bharat Rawal Bryan and Vincent, **Cybersecurity and Identity Access Management**
- “**Web Application Security, A Beginners Guide**”, McGraw-Hill, 2011
- Bhavani Thuraisingham, **Database and Applications Security, Integrating Information Security and Data Management**, Auerbach Publications, 2005.

Domain 4 : **Security Assessment Total Hours – 8 Hours**

- Unit 1: Ethical Hacking and Pen Testing
  - Internal, External and third-party testing. Information Gathering, Vulnerability assessment, Security vulnerabilities and countermeasures. Owasp top 10 attacks, Web server attacks: XSS attacks, CSRF Attacks
  - Application related attacks, Database Related attacks, SQL injection attacks, Buffer overflow attacks and Client-side browser exploits, Penetration testing, Introducing Metasploit
  - Social Engineering attacks, Password attacks, Privilege Escalation, ICS Related attacks, Network Infrastructure Vulnerabilities, IP spoofing, DNS spoofing, Wireless Hacking, WPA, WEP, WPA2
- Unit 2 : Logging and Monitoring
  - IDS, SIEM, UEBA, SOAR, Threat Intelligence (Dark web vs Surface web), Log Management, Continuous monitoring, Egress monitoring, EDR, PCAP, NDR
  - SDLC Integrated Security: Maturity models, Software development methods, Change Management, SAST and DAST, Testing a system, Verification vs validation, Testers and Assessors (SOC1 vs SOC2 vs SOC2, Type 1 and Type 2), Metrics (KPI, KRI)

**Suggested Readings**

- Jon Friedman, Mark Bouchard, CISSP, Cyber Threat Intelligence, Definitive Guide™ 2015 .
- Baloch, R., **Ethical Hacking and Penetration Testing Guide**, CRC Press, 2015.
- McClure S., Scambray J., and Kurtz G, **Hacking Exposed**, 6th Edition, Tata McGraw-Hill Education, 2009
- Ross J Anderson, **Security Engineering: A Guide to Building Dependable Distributed Systems**, 2nd Edition, Wiley, 2008.
- Julia H Allen, Sean J Barnum, Robert J Ellison, Gary McGraw, Nancy R Mead, **Software Security Engineering: A Guide for Project Managers**, Addison Wesley, 2008.

**Text Books**

1. Michael E. Whitman, Herbert J. Mattord, Principles of Information Security, 6th Edition, Cengage Learning, 2018.
2. Van Kessel, P., **Is cyber security about more than protection?**, EY Global Information Security Survey 2018-2019.
3. Johnston, A.C. and Warkentin, M., **Fear appeals and information security behaviors: An empirical study**, MIS Quarterly, 2010.

**References**

1. Arce I. et al., **Avoiding the top 10 software security design flaws**, IEEE Computer Society Center for Secure Design (CSD), 2014.
2. Smith, H. J., Dinev, T., & Xu, H., **Information privacy research: an interdisciplinary review**, MIS Quarterly, 2011.
3. Subramanian R., **Security, privacy and politics in India: a historical review**, Journal of Information Systems Security (JISec), 2010.
4. Acquisti, A., John, L. K., & Loewenstein, G., **What is privacy worth?**, The Journal of Legal Studies, 2013
5. Xu H., Luo X.R., Carroll J.M., Rosson M.B., **The personalization privacy paradox: An exploratory study of decision making process for location-aware marketing**, Decision Support Systems, 2011.